

איך לקרוא את הפרק הזה

בפרק הקודם הבנו מפני מה מגנים ומי התוקפים. בפרק הזה מתחילים להגן בפועל – על הרכיב הראשון והחשוב ביותר ברשת: הנתב. הפרק כתוב לקריאה רציפה גם למי שלא ראה מעולם ציוד רשת. נתחיל מהבסיס ממש (מה זה נתב, איך "מדברים" איתו), ורק אז נראה פקודות. כל פקודה מוסברת במילים לפני שהיא מופיעה.

2.1 למה מתחילים דווקא מהנתב?

נזכיר מהפרק הקודם: **נתב** (Router) הוא המכשיר שמעביר את התעבורה בין רשתות שונות – למשל בין הרשת של בית הספר לבין האינטרנט. הנתב שיושב על הגבול הזה נקרא **נתב קצה** (Edge Router), והוא נקודת המפגש בין הרשת שלנו לעולם החיצון.

למה הוא המטרה הראשונה של תוקפים? כי מי ששולט בנתב שולט בכל מה שעובר דרכו. הוא יכול לצותת לכל התעבורה, לחסום אותה, להטות אותה למקום אחר, או לפתוח דרכה דלת אל תוך הרשת. במילים אחרות, הנתב הוא כמו השומר בשער: אם הוא נפרץ, כל שאר ההגנות שמאחוריו כבר לא עוזרות. לכן הצעד הראשון בכל רשת מאובטחת הוא "להקשיח" את הנתב.

הקשחה (Hardening) פירושה להפוך מכשיר מהגדרת ברירת המחדל ה"פתוחה" שלו למצב מאובטח: לתת סיסמאות חזקות, לאפשר גישה מוצפנת בלבד, לכבות שירותים מיותרים, ולהפעיל ניטור. את כל אלה נלמד בפרק. נהוג לחלק את אבטחת הנתב לשלושה תחומים: אבטחה **פיזית** (מי בכלל יכול לגעת בו – חדר נעול), אבטחת **מערכת ההפעלה** (גרסה עדכנית וגיבוי), ו**הקשחה** של ההגדרות (לב הפרק).

מהעולם האמיתי: חצי מיליון נתבים נחספו (VPNFilter, 2018)

נזקק בשם VPNFilter הדביקה מעל 500,000 נתבים ביתיים וקטנים בעולם. היכולות שלה היו מפחידות: לרגל אחר כל התעבורה שעוברת בנתב, לגנוב סיסמאות, ואף "להרוג" את הנתב בפקודה אחת. ה-FBI ייחס אותה לתקיפה מדינתית והשתלט על שרת השליטה שלה כדי לעצור אותה. איך היא נכנסה? דרך חולשות ידועות שלא עודכנו וסיסמאות ברירת מחדל שלא שוננו. הלקח: נתב הוא מחשב מלא לכל דבר, ובלי הקשחה הוא הדלת הקלה ביותר פנימה.

2.2 איך בכלל "מדברים" עם נתב?

בניגוד למחשב רגיל, לנתב אין מסך, עכבר וחלונות. מנהלים אותו בעזרת CLI (Command Line Interface) – "ממשק שורת פקודה", כלומר מקלידים פקודות טקסט והנתב מגיב. מערכת ההפעלה של ציוד סיסקו נקראת IOS (כמו ש-Windows היא מערכת ההפעלה של המחשב, IOS היא מערכת ההפעלה של הנתב), וה-CLI הוא הדרך לדבר איתה.

מצבי העבודה – והסימן שאומר לכם איפה אתם

ל-CLI יש כמה "מצבים" (רמות), וכל אחד מאפשר דברים אחרים. הדבר החשוב: סיאצמן שתא בצמ הזיבא סכל רמוא דימת רסמה לע עיפומש נמיסה. הסימן בנוי משלושה חלקים: שם הנתב, ואחריו – בסוגריים – החלק שאתם מגדירים כרגע, ואחריו הסימן > או #. הסימן > אומר "אתם רק יכולים להסתכל", והסימן # אומר "אתם מנהלים ומותר לכם לשנות" (חשבו על # כמו על מנהל/ root).

- **R1> – מצב משתמש (User).** זה מה שרואים מיד בכניסה. אפשר רק להסתכל: פקודות show בסיסיות, ping.
- **R1# – מצב מנהל (Privileged).** מגיעים אליו בהקלדת enable. כאן מותר הכול, כולל לצפות בכל ההגדרות ולאתחל את הנתב.
- **R1(config)# – מצב הגדרות (Global config).** מגיעים אליו בהקלדת configure terminal. כאן משנים הגדרות של הנתב כולו (שם, משתמשים, ניתוב).
- **R1(config-if)# – מצב ממשק (Interface).** מגיעים אליו בהקלדת למשל interface g0/0, ומגדירים פורט מסוים. (ממשק / Interface הוא פשוט פורט/קרטיס רשת בנתב, למשל GigabitEthernet0/0, בקיצור g0/0.)

מושג חשוב: איפה נשמרות ההגדרות?

לנתב יש שני "עותקים" של ההגדרות. running-config הוא הקונפיגורציה הפעילה כרגע – אבל היא נמצאת בזיכרון זמני ויוביכב תקחמנ. startup-config היא הקונפיגורציה השמורה, שנטענת מחדש בכל הדלקה. לכן אחרי שמסיימים להגדיר – חייבים לשמור, בפקודה write (או copy running-config startup-config). מי ששוכח לשמור מגלה שכל עבודתו נעלמה אחרי אתחול.

הנה "סיפור" קצר של פקודות. קראו את הסימן בתחילת כל שורה כדי לעקוב איפה אנחנו נמצאים:

```
Router> enable "ממצב "להסתכל" למצב "מנהל" !
Router# configure terminal נכנסים למצב הגדרות !
Router(config)# hostname R1 נותנים לנתב שם - שימו לב שהסימן משתנה מיד !
R1(config)# interface g0/0 נכנסים לפורט מסוים !
R1(config-if)# no shutdown מדליקים את הפורט !
R1(config-if)# end חוזרים ישר למצב מנהל !
R1# write שומרים! (אחרת ההגדרות ייעלמו בכיבוי) !
```

2.3 סיסמאות: מה חזק, מה חלש, ולמה

הצעד הבסיסי בהקשחה הוא סיסמאות טובות. ב-IOS יש כמה סוגים של סיסמאות, וההבדל ביניהן קריטי. הכלל הפשוט: תמיד להשתמש במילה secret, אף פעם לא במילה password.

```
R1(config)# enable secret Str0ng-P@ss ! סיסמת מצב מנהל - מאוחסנת מגובבת (בטוח)
R1(config)# enable password weak ! מאוחסנת בטקסט גלוי - לא להשתמש !
R1(config)# service password-encryption מסתיר את הסיסמאות הגלויות בקונפיג !
R1(config)# username admin secret P@ss משתמש מקומי עם סיסמה מגובבת
```

למה secret עדיף? כי הוא נשמר כ**היבוב** (hash) – טביעת אצבע חד-כיוונית של הסיסמה, שממנה אי אפשר לשחזר את הסיסמה המקורית (נרחיב על גיבוב בפרק 7). לעומת זאת password נשמר בטקסט גלוי, וגם הפקודה service password-encryption שמסתירה אותו משתמשת בהצפנה חלשה מאוד (מה שנקרא "type 7") שנשברת בשינוי באתרים חנימיים באינטרנט. לכן service password-encryption מגן רק מפני מישו שמציץ מעבר לכתף בזמן שאתם צופים בקונפיג – לא מפני תוקף אמיתי. ההגנה האמיתית היא ה-secret.

הגנה מפני ניחוש סיסמאות

סיסמה חזקה היא רק חצי מהסיפור – כדאי גם למנוע מתוקף לנסות רופסניא ניחושים. ל-IOS יש מנגנון מובנה לכך: אחרי מספר ניסיונות כושלים בפרק זמן נתון, הנתב "ננעל" לזמן מה ולא מקבל ניסיונות חדשים. זה הופך התקפת ברוט-פורס (ניחוש שיטתי) מבלתי-מעשית.

```
R1(config)# login block-for 120 attempts 3 within 60 ! 3 כישלונות תוך 60 שני → נעילה ל-120 שני
R1(config)# login delay 2 ! השהיה של 2 שני בין ניסיונות
R1(config)# login on-failure log ! רשום כל כישלון ליומן
```

בנוסף, כדאי להגדיר exec-timeout על קווי הגישה – ניתוק אוטומטי אחרי כמה דקות של חוסר פעילות, כדי שמסך פתוח ונטוש לא יישאר גישה פתוחה למי שיעבור לידו:

```
R1(config)# line vty 0 4
R1(config-line)# exec-timeout 5 0 ! ניתוק אחרי 5 דקות ללא פעילות
```

2.4 Telnet מול SSH – ההבדל שמציל אתכם

כדי לנהל נתב מרחוק (מבלי להתחבר אליו פיזית בכבל), מתחברים אליו דרך הרשת. יש לכך שני פרוטוקולים, ואחד מהם מסוכן מאוד.

Telnet (פורט 23) הוא הפרוטוקול הישן. הבעיה שלו חמורה: הוא מעביר את לוכה בטקסט גלוי, כולל את שם המשתמש והסיסמה. כל מי ש"מקשיב" לרשת יכול לראות אותם. SSH (Secure Shell) (פורט 22) הוא הפרוטוקול המאובטח: הוא יפצמ את כל התקשורת, כך שמאזין רואה רק ג'יבריש, וגם מוודא שאתם מדברים

באמת עם הנתב הנכון. משתמשים ב-SSH גרסה 2 בלבד.

מהעולם האמיתי: Telnet שנלכד בבית חולים

בבדיקת חדירה מוזמנת, הבודק חיבר מחשב נייד לשקע רשת בחדר המתנה והריץ תוכנה שמקשיבה לתעבורה (Wireshark). תוך 40 דקות הוא לכד תקשורת Telnet של טכנאי שהתחבר למתג הראשי - ושם המשתמש והסיסמה השתקפו על מסכו בטקסט גלוי. עם הסיסמה הזו הוא קיבל שליטה בכל המתגים בבניין. הטכנאי לא עשה שום דבר "לא נכון" - הוא פשוט השתמש בכלי הישן שהיה זמין. ההגנה מפני כל התרחיש הזה היא שורה אחת שחוסמת Telnet ומחייבת SSH.

הגדרת SSH - חמישה שלבים, כל אחד מוסבר

כדי ש-SSH יעבוד, הנתב צריך לייצר לעצמו **זוג מפתחות RSA** - מפתח ציבורי ומפתח פרטי (נבין אותם לעומק בפרק 7). המפתחות האלה הם מה שמצפין את החיבור. כדי לייצר אותם, הנתב חייב קודם שם מלא, שמורכב מהשם שלו (hostname) ומשם דומיין. לכן שני אלה חייבים לבוא ראשונים:

```
R1(config)# hostname R1 ! 1. שם לנתב
R1(config)# ip domain-name school.local ! 2. שם דומיין (חובה לפני יצירת מפתחות)
R1(config)# crypto key generate rsa modulus 2048 ! 3. ייצור זוג מפתחות RSA
R1(config)# username admin privilege 15 secret P@ss ! 4. משתמש שאיתו נתחבר
R1(config)# ip ssh version 2 ! SSHv2 בלבד
R1(config)# line vty 0 4 ! 5. הגדרת קווי הגישה מרחוק
R1(config-line)# login local ! אימות מול המשתמש המקומי
R1(config-line)# transport input ssh Telnet חוסם - SSH !
```

הטעות הנפוצה ביותר

אם שוכחים את שורת ip domain-name (או משאירים את שם הנתב כברירת המחדל ("Router", הפקודה crypto key generate rsa נכשלת עם ההודעה "Please define a domain-name first"). זכרו: השם והדומיין חייבים לבוא ינפל יצירת המפתחות, כי שם המפתח נגזר מהם.

הערה על line vty 0 4: VTY הם קווי הגישה הווירטואליים שדרכם מתחברים מרחוק (יש חמישה כאלה, ממוספרים 0 עד 4). עליהם אנחנו קובעים שני דברים: login local - שהאימות יעשה מול מסד המשתמשים המקומי (כלומר יידרש גם שם וגם סיסמה), ו-transport input ssh - שמותר להתחבר רק ב-SSH ולא ב-Telnet.

login מול login local - הבחנה שנשאלת בבגרות

login (לבד) מבקש רק סיסמה אחת משותפת של הקו, בלי שם משתמש. login local מבקש גם שם משתמש וגם סיסמה, ומאמת אותם מול מסד המשתמשים המקומי (secret ... username). מכיוון ש-SSH דורש שם משתמש, הוא חייב login local - ולכן זו התשובה הנכונה בשאלות בגרות על התחברות מאובטחת.

2.5 עוד כלי הקשחה: רמות הרשאה ו-Banner

רמות הרשאה (Privilege Levels): לפעמים רוצים לתת למישהו גישה חלקית - למשל למתמחה שיוכל רק לצפות, בלי לשנות. ל-IOS יש 16 רמות הרשאה (0 עד 15). רמה 1 היא ברירת המחדל (רק צפייה), רמה 15 היא הרשאת מנהל מלאה, ואת הרמות שביניהן אפשר להתאים אישית ולהעביר אליהן פקודות מסוימות. כך אפשר לתת לכל תפקיד בדיוק את מה שהוא צריך - עיקרון שנקרא "מינימום הרשאות".

Banner: זוהי הודעת אזהרה שמופיעה בכניסה לנתב. מטרתה משפטית - להבהיר שהגישה מיועדת למורשים בלבד ושהפעילות מנוטרת.

```
R1(config)# banner motd #
***
תדעו! תרנום תוליעה . הרוסא תישרום יתלב השיג ***
#
```

מה לא לכתוב בבאנר

לא לכתוב "Welcome" (ברוכים הבאים) - במקרה משפטי בארה"ב פורץ טען שהבאנר "הזמין" אותו להיכנס. לא לכתוב את שם החברה ולא את דגם הנתב - זה רק עוזר לתוקף. הבאנר צריך רק להזהיר, לא לקבל את פני האורח.

מהעולם האמיתי: הדגל האמריקאי על 168,000 נתבים (2018)

קבוצת האקרים גילתה שירות ניהול של סיסקו בשם Smart Install שנשאר פתוח וחשוף לאינטרנט אצל עשרות אלפי ארגונים. הם מצאו את הנתבים החשופים דרך מנוע חיפוש בשם Shodan, איפסו את הקונפיגורציה של כ-168,000 נתבים, ובחלקם השאירו הודעה עם דגל אמריקאי וכיתוב "אל תתעסקו עם הבחירות שלנו". נפגעו ספקיות אינטרנט באיראן וברוסיה. הלקח ישיר: שירות ניהול מיותר שנשאר פתוח הוא הזמנה - ולכן מכבים כל שירות שלא נחוץ (הנושא של סעיף 2.7).

רמות הרשאה בפירוט, ותצוגות תפקיד

הרחבנו קודם שיש 16 רמות הרשאה. בפועל משתמשים בשלוש: רמה 1 (המשתמש הרגיל - רק צפייה), רמה 15 (מנהל מלא), ורמות ביניים שאליהן אפשר "להעביר" פקודות מסוימות. לדוגמה, אפשר ליצור רמה 5 שמותר לה גם לאתחל את הנתב ולצפות בהגדרות, ולתת אותה לצוות התמיכה:

```
R1(config)# privilege exec level 5 reload ! רמה 5 יכולה לאתחל
R1(config)# enable secret level 5 Lvl5-P@ss
R1(config)# username helpdesk privilege 5 secret Help-P@ss
```

לרמות ההרשאה יש חיסרון: רמה גבוהה מקבלת אוטומטית גם את כל מה שמותר ברמות שמתחתיה, ואין שליטה מדויקת. פתרון מדויק יותר הוא **תצוגות תפקיד** (Role-Based CLI View) - "תצוגה" שמכילה רשימת פקודות מדויקת שהמשתמש רשאי להריץ, ותו לא. כך אפשר לתת לכל תפקיד בדיוק את מה שהוא צריך (עיקרון "מינימום הרשאות"). הגדרת תצוגות דורשת שמנגנון ה-AAA יופעל (נלמד עליו בפרק 3).

שמירה והגנה על ההגדרות וה-IOS

תוקף שהצליח להיכנס עלול למחוק את מערכת ההפעלה (IOS) ואת קובץ ההגדרות כדי לשתק את הנתב לגמרי. תכונת IOS Resilient Configuration שומרת עותק מוגן שלא ניתן למחוק דרך שורת הפקודה - מעין "גיבוי חסין" בתוך הנתב עצמו:

```
R1(config)# secure boot-image ! מגן על קובץ מערכת ההפעלה
R1(config)# secure boot-config ! מגן על קובץ ההגדרות
```

בנוסף לגיבוי החסין, נהוג לגבות את ההגדרות באופן שוטף לשרת חיצוני (copy running-config tftp:) ולתעד מי שינה מה - מה שנקרא **ביקורת** (Auditing). תיעוד כזה עונה על השאלה החשובה "מי הקליד את הפקודה הזו ומתי?", ומשלים את ה-syslog שנכיר מיד.

2.6 ניטור: לדעת מה קורה בנתב

אבטחה טובה היא לא רק חסימה - היא גם לדעת מה קורה. לשם כך יש שלושה שירותים שכדאי להפעיל.

Syslog - יומן האירועים

הנתב מייצר כל הזמן הודעות על אירועים: ממשק שעלה או נפל, ניסיון כניסה כושל, חבילה שנחסמה. Syslog הוא המנגנון ששולח את ההודעות האלה לשרת **מרכזי** (על פורט 514 UDP) למה שרת מרכזי ולא רק בנתב עצמו? כי תוקף חכם שמצליח להיכנס לנתב ימחק את היומן המקומי כדי לטשטש עקבות - אבל אין לו גישה לשרת החיצוני, ושם הראיות נשמרות.

```
R1(config)# logging host 10.0.0.5 ! שולח את היומן לשרת
R1(config)# logging trap warnings ! שולח רמות 0 עד 4
```

להודעות היומן יש 8 **רמות חומרה**, מ-Emergency (0, החמור ביותר) עד Debug (7, מידע פנימי מפורט). כשבוחרים רמה מקבלים אותה וכל מה שחמור ממנה - למשל אם בוחרים רמה (warnings) 4 מקבלים את רמות 0 עד 4.

NTP – למה זמן מדויק הוא עניין של אבטחה

NTP (Network Time Protocol) מסנכרן את השעון של כל הציוד ברשת למקור זמן אחד. זה נשמע טכני ומשעמם, אבל הוא קריטי לאבטחה: בלי זמן מסונכרן, אי אפשר לשחזר את סדר האירועים בזמן חקירה. אם הנתב מראה שעה אחת והשרת שעה אחרת, לא תדעו אם הכניסה הכושלת לנתב קרתה לפני החדירה לשרת או אחריה. חוץ מזה, גם תעודות דיגיטליות ומפתחות VPN תלויים בשעון נכון.

```
R1(config)# ntp server 10.0.0.5
```

SNMP – ניטור מצב הציוד

SNMP הוא פרוטוקול שמאפשר לתחנת ניהול מרכזית לאסוף נתונים מהנתב (כמה תעבורה עוברת, עומס המעבד). הבעיה: בגרסאות הישנות (v1, v2c) הגישה מאובטחת רק ב"מחרוזת קהילה" (community string) שעוברת בטקסט גלוי, ולעיתים קרובות נשארת ברירת המחדל "public". רק גרסה 3 (SNMPv3) מוסיפה אימות והצפנה אמיתיים. הכלל: אם משתמשים ב-SNMP, גרסה 3 בלבד.

מהעולם האמיתי: Shodan – "גוגל של המכשירים המחוברים"

Shodan הוא מנוע חיפוש שסורק כל הזמן את האינטרנט ומקטלג מכשירים חשופים – נתבים, מתגים, מצלמות אבטחה. אפשר לחפש בו מכשירים עם "public" SNMP, עם Telnet פתוח, או עם סיסמת ברירת מחדל, ולקבל רשימה של אלפים. תוקפים משתמשים בו לשלב הסיוור (פרק 1); אנשי אבטחה משתמשים בו כדי לגלות מה הארגון שלהם חושף בטעות. כל פעולת הקשחה שאנחנו לומדים בפרק הזה מורידה אתכם מהרשימה של Shodan.

עוד על שלושת שירותי הניטור

שמונה רמות החומרה של Syslog – כדאי להכיר אותן, כי בוחרים לפיהן מה לשלוח לשרת. הן, מהחמורה ביותר לפחותה: 0 – Emergency (המערכת אינה שמישה), 1 – Alert (נדרשת פעולה מיידי), 2 – Critical, 3 – Error (למשל ממשק שנפל), 4 – 5 – Notification – Warning (אירוע רגיל אך חשוב, כמו שינוי הגדרות), 6 – Debugging – Informational, 7 (פלט מפורט מאוד לאיתור תקלות). מנמוניקה נפוצה לזכירת הסדר באנגלית: Every Awesome Cisco Engineer Will Need Ice-cream Daily.

ל-NTP יש מושג בשם Stratum – "מרחק" ממקור הזמן המדויק. Stratum 0 הוא שעון אטומי או GPS, Stratum 1 הוא שרת שמחובר אליו ישירות, וכן הלאה. ככל שה-Stratum נמוך יותר, המקור אמין יותר. חשוב גם תמאל את מקור הזמן (ntp authenticate), אחרת תוקף יכול לזייף לנתב את השעה ובכך לשבש לוגים ותעודות.

ב-SNMPv3 יש שלוש רמות אבטחה שכדאי להכיר: noAuthNoPriv (בלי אימות ובלי הצפנה – החלש), au-thNoPriv (אימות בלבד), ו-authPriv (גם אימות וגם הצפנה – המומלץ). המילה "auth" מציינת אימות (מי שולח) ו-"priv" מציינת פרטיות/הצפנה (שאף אחד לא יקרא). זה ההבדל המהותי מ-v1/v2c, שאין בהם לא אימות אמיתי ולא הצפנה.

2.7 כיבוי שירותים מיותרים ו-AutoSecure

נתב מגיע מהמפעל עם הרבה שירותים דלוקים שהיו שימושיים פעם והיום הם רק שטח תקיפה מיותר. עיקרון ההקשחה פשוט: **כל שירות שלא צריך – כבה אותו**. כל שירות פתוח הוא דלת אפשרית (זכרו את סיפור Cisco Smart Install!).

```
R1(config)# no ip http server מיותר web מיותר !
R1(config)# no cdp run ! פרוטוקול שחושף דגם וגרסה לשכנים
```

כדי לחסוך זמן, קיימת פקודה אחת שמבצעת חלק גדול מההקשחה אוטומטית: AutoSecure. היא מכבה שירותים מסוכנים, מפעילה ניטור, ומקשיחה את הנתב בכמה שאלות פשוטות.

```
R1# auto secure
```

זהירות עם AutoSecure

היא "עיוורת" – עלולה לכבות דברים שהרשת בכל זאת צריכה (למשל CDP שהמתגים משתמשים בו). לכן מריצים אותה, בודקים מה היא שינתה בעזרת `show auto secure config`, ומכוונים לפי הצורך.

2.8 עוד דוגמאות מהעולם האמיתי

שלושת הסיפורים בפרק – VPNFilter, הדגל האמריקאי (Cisco Smart Install) ו-Shodan – אינם אנקדוטות; הם ההוכחה החיה לכל מה שלמדנו. בכל אחד מהם, נתב או שירות שלא הוקשח היה הדלת פנימה: סיסמת ברירת מחדל שלא שונתה, שירות מיותר שנשאר פתוח, או ניהול לא מוצפן שנחשף. שורת המחץ של הפרק: הקשחה הופכת את הנתב משער פתוח לשער נעול.

2.9 תרגילים – עם פתרונות

תרגיל 1 – מצאו את הבעיות בקונפיג

```
Router(config)# enable password cisco Router(config)# line vty 0 4 Router(config-line)# password cisco Router(config-line)# login Router(config-line)# transport input telnet # !Router(config)# banner motd # Welcome to ACME Corp
```

1. enable password (גלוי) במקום enable secret. 2. הסיסמה "cisco" חלשה מאוד. 3. login בלי שם משתמש (צריך login עם username). 4. transport input telnet – לא מוצפן, צריך ssh. 5. באנר "Welcome" עם שם החברה. 6. השם נשאר "Router" ואין ip domain-name – כך שאי אפשר בכלל ליצור מפתחות ל-SSH.

תרגיל 2 – סדרו את הפקודות

באיזה סדר צריך להריץ כדי ש-SSH יעבוד?
line vty 0 4 · ip domain-name lab.local · transport input ssh · name R1
line vty → crypto key generate rsa → ip domain-name lab.local → hostname R1
0 4 → login local → transport input ssh. השם והדומיין חייבים לבוא לפני יצירת המפתחות.

תרגיל 3 – למה שרת syslog מרכזי?

תוקף הצליח להיכנס לנתב. מדוע עדיף שהיומן יישלח לשרת חיצוני ולא יישמר רק בנתב עצמו?
כי תוקף עם גישה לנתב יכול למחוק את היומן המקומי כדי לטשטש את עקבותיו. ליומן שנשלח לשרת חיצוני אין לו גישה, ולכן הראיות נשמרות שם – מה שמאפשר לחקור את האירוע.

תרגיל 4 – תכנון הקשחה

אתם מנהלי הרשת של בית ספר עם שלושה נתבים. כתבו שישה צעדי הקשחה שתבצעו על כל נתב, לפי סדר עדיפות, ונמקו את הראשון.

דוגמה: 1. enable secret + secret ... username – בלי הגנת סיסמה בסיסית כל השאר חסר ערך. 2. SSH בלבד (login local + transport input ssh), כיבוי. 3. Telnet block- login for נגד ניחוש סיסמאות. 4. syslog + NTP. 5. SNMPv3. 6. באנר אזהרה + גיבוי הקונפיג.

בנק שאלות שתלמידים שואלים – ותשובות מוכנות

שאלות נפוצות בפרק הקשחת הנתב, עם תשובות מוכנות.

סיסמאות וגישה

ש: "אם אני שם סיסמה חזקה ל-Telnet, למה בכל זאת צריך SSH?"
ת: כי Telnet מעביר את לונה בטקסט גלוי, כולל את הסיסמה החזקה עצמה. כל מי שמאזין לרשת (Wireshark) רואה אותה. SSH מצפין את כל התקשורת. חוזק הסיסמה לא עוזר אם היא נשלחת גלויה.

ש: "מה ההבדל בין password ל-secret?"
ת: secret נשמר כינוויכ-דח בוביג (לא ניתן לשחזר). password נשמר גלוי, ואפילו עם service password-encryption הוא רק "7" type שמפוענח באתר אונליין בשנייה. תמיד להשתמש ב-secret.
ש: "אם service password-encryption זו הצפנה, למה היא חלשה?"

ת: כי זה אלגוריתם הפיך וישן (וריאציה על Vigen). הוא מגן רק מפני מישהו שמציץ מעבר לכתף בזמן שאתם צופים בקונפיג - לא מפני תוקף אמיתי. ה"חוזק" האמיתי הוא ב-secret (גיבוב).

ש: "מה קורה אם שכחתי את ה-enable secret?"

ת: יש הליך password recovery דרך גישה פיזית לקונסול: מאתחלים, נכנסים ל-ROMMON, משנים את ה-configuration register (0x2142) כדי לדלג על ה-startup-config, ומגדירים סיסמה חדשה. המסקנה החשובה: וב טלוש - בתנל תיזיפ השיג ול שיש ימ, ולכן אבטחה פיזית קריטית.

ש: "מה ההבדל בין רמות הרשאה (privilege levels) לתצוגות (views)?"

ת: רמות הרשאה גסות - רמה נתונה מקבלת אוטומטית גם את כל מה שמתחתיה. תצוגות (parser view) מדויקות - מגדירים רשימת פקודות מדויקת לכל תפקיד, אך דורשות שה-AAA יופעל.

SSH

ש: "למה צריך ip domain-name כדי ליצור מפתחות SSH?"

ת: כי שם המפתח נגזר מהשם המלא של הנתב = hostname + domain-name (FQDN). הנתב לא יודע איזה שם לתת למפתח, והפקודה נכשלת עם "Please define a domain-name first".

ש: "אחרי transport input ssh ניתקתי בטעות את Telnet - זו טעות?"

ת: לא, זה בדיוק מה שרוצים - לחסום את Telnet הלא-מאובטח ולאפשר רק SSH. חיבור Telnet חדש ייכשל, וזו התנהגות רצויה.

שירותים וניטור

ש: "למה זמן מדויק (NTP) קשור לאבטחה בכלל?"

ת: כי בלי זמן מסונכרן, הלוגים מכל המכשירים לא ניתנים לשחזור - אי אפשר לדעת מה קרה לפני מה כשחוקרים אירוע. בנוסף, תעודות דיגיטליות ומפתחות VPN תלויים בזמן נכון.

ש: "SNMPv2 באמת כל כך גרוע?"

ת: הבעיה שלו היא ה-community string (ולעיתים נשאר "public" אם חייבים v2c) - לפחות read-only + הגבלה ב-ACL לכתובת תחנת הניהול. אבל הנכון הוא v3, שמוסיף אימות (HMAC) והצפנה.

ש: "אז למה שלא נריץ תמיד auto secure ונגמור עם זה?"

ת: כי הוא "עיוור" - יכול לכבות CDP שהמתגים צריכים, להפעיל חומת אש שתחסום תעבורה לגיטימית, ואי אפשר לבטלו בפקודה אחת. מריצים אותו, בודקים מה שינה עם show auto secure config, ומכוונים.

ש: "מה זה בעצם CLI, ולמה לא ללמוד ממשק גרפי?"

ת: CLI הוא ממשק שורת הפקודה של הנתב. אנחנו לומדים אותו כי הוא אוניברסלי (עובד על כל ציוד סיסקו וגם דרך SSH, מדויק, וניתן לאוטומציה - דבלב ותוא תקדוב תורגבה). הממשקים הגרפיים (SDM/CCP) יצאו משימוש.

מילון מונחים - הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה (מותר מילון מונחים).

מונח	הגדרה
CLI (Command Line Interface)	ממשק שורת פקודה לניהול ציוד רשת בהקלדת פקודות טקסט.
IOS	מערכת ההפעלה של ציוד סיסקו.
running-config	ההגדרות הפעילות בזיכרון; נמחקות בכיבוי אם לא נשמרו.
startup-config	ההגדרות השמורות שנטענות באתחול הנתב.
Console / VTY / AUX	דרכי גישה לנתב: קונסול (פיזי), VTY (מרחוק ברשת), AUX (מודם ישן).
In-band / OOB	ניהול דרך רשת הנתונים (In-band) או דרך רשת ניהול נפרדת (Out-of-band).
enable secret	סיסמת מצב מנהל, נשמרת כגיבוב חד-כיווני (בטוח).
service password-encryption	מסתיר סיסמאות בקונפיג בהצפנה חלשה (type 7) - מגן רק מהצצה.

מונח	הגדרה
SSH (Secure Shell)	פרוטוקול ניהול מרחוק מוצפן (פורט 22); מחליף את Telnet הלא-מאובטח.
Telnet	פרוטוקול ניהול מרחוק לא מוצפן (פורט 23) - מסוכן, לא לשימוש.
מפתחות RSA	זוג מפתחות (ציבורי/פרטי) שהנתב מייצר כדי לאפשר SSH. הצפנת SSH.
רמות הרשאה (Privilege levels)	16 רמות (0)-(15) הקובעות אילו פקודות מותרות; 15 = הכול.
Parser View	תצוגת תפקיד - רשימת פקודות מדויקת למשתמש; דורשת AAA.
Banner	הודעת אזהרה משפטית המוצגת בכניסה לנתב.
Syslog	מנגנון יומן אירועים; שולח הודעות לשרת מרכזי (UDP 514).
Severity levels	8 רמות חומרה ליומן (0=Emergency החמור ביותר עד 7=Debug).
NTP (Network Time Protocol)	מסנכרן שעונים בכל הציוד (UDP 123); קריטי ללוגים ולתעודות.
SNMP	פרוטוקול לניטור ציוד (UDP 161); גרסה 3 בלבד מאובטחת.
AutoSecure	פקודה שמבצעת הקשחה אוטומטית של הנתב בצעד אחד.
Hardening (הקשחה)	סגירת שירותים מיותרים והגדרות אבטחה למזעור שטח התקיפה.
err-disabled	מצב שבו פורט מושבת אוטומטית עקב הפרת אבטחה.